Threagile
Agile Threat Modeling

Threat Model Report
Obsidian TTS

7 March 2026

vonst

Table of Contents

Results Overview

Management Summary 4
Impact Analysis of 16 Initial Risks in 15 Categories 5
Risk Mitigation 7
Impact Analysis of 16 Remaining Risks in 15 Categories 8
Application Overview 10
Data-Flow Diagram 11
Security Requirements 12
Abuse Cases 13
Tag Listing 14
STRIDE Classification of Identified Risks 15
Assignment by Function 18
RAA Analysis 20
Data Mapping 21
Out-of-Scope Assets: 2 Assets 22
Potential Model Failures: 4 / 4 Risks 23
Questions: 3 / 3 Questions 24

Risks by Vulnerability Category

Identified Risks by Vulnerability Category 25
T1 API Key Plaintext in data.json: 1 / 1 Risk 26
T3 Audio Output Path Traversal: 1 / 1 Risk 28
T8 API Key Leakage in Logs: 1 / 1 Risk 30
Missing Cloud Hardening: 1 / 1 Risk 32
Missing File Validation: 1 / 1 Risk 35
Missing Hardening: 1 / 1 Risk 37
Path-Traversal: 1 / 1 Risk 39
Unguarded Access From Internet: 1 / 1 Risk 41
Missing Build Infrastructure: 1 / 1 Risk 43
Missing Identity Store: 1 / 1 Risk 45
Missing Network Segmentation: 1 / 1 Risk 47
Missing Two-Factor Authentication (2FA): 1 / 1 Risk 49
Missing Vault (Secret Storage): 1 / 1 Risk 51
Unencrypted Technical Assets: 2 / 2 Risks 53
Wrong Communication Link Content: 1 / 1 Risk 55

Risks by Technical Asset

Identified Risks by Technical Asset 57
Obsidian Vault Storage: 6 / 6 Risks 58
Obsidian Plugin Runtime: 8 / 8 Risks 61
Obsidian End User: out-of-scope 65
ElevenLabs API: out-of-scope 67

Data Breach Probabilities by Data Asset

Identified Data Breach Probabilities by Data Asset 69
ElevenLabs API Key: 12 / 12 Risks 70
Generated Audio Files: 12 / 12 Risks 71
Obsidian Plugin Settings: 11 / 11 Risks 72
Plugin Execution Logs: 11 / 11 Risks 73
Selected Note Text: 12 / 12 Risks 74

Trust Boundaries

ElevenLabs Cloud 75
Local User Workstation 75

About Threagile

Risk Rules Checked by Threagile 77
Disclaimer 90

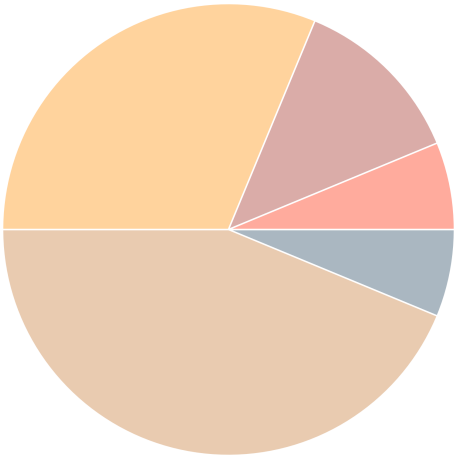
Management Summary

Threagile toolkit was used to model the architecture of "Obsidian TTS" and derive risks by analyzing the components and data flows. The risks identified during this analysis are shown in the following chapters. Identified risks during threat modeling do not necessarily mean that the vulnerability associated with this risk actually exists: it is more to be seen as a list of potential risks and threats, which should be individually reviewed and reduced by removing false positives. For the remaining risks it should be checked in the design and implementation of "Obsidian TTS" whether the mitigation advices have been applied or not.

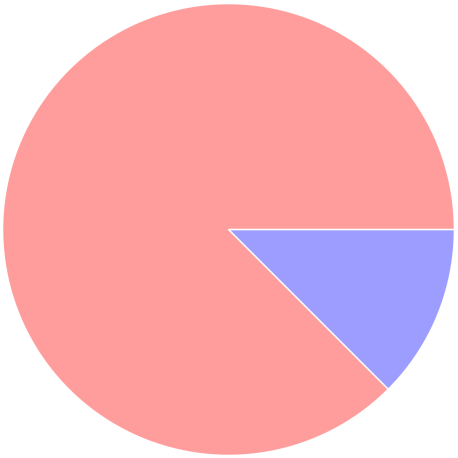
Each risk finding references a chapter of the OWASP ASVS (Application Security Verification Standard) audit checklist. The OWASP ASVS checklist should be considered as an inspiration by architects and developers to further harden the application in a Defense-in-Depth approach. Additionally, for each risk finding a link towards a matching OWASP Cheat Sheet or similar with technical details about how to implement a mitigation is given.

In total **16 initial risks** in **15 categories** have been identified during the threat modeling process:

1 critical risk
2 high risk
5 elevated risk
7 medium risk
1 low risk



14 unchecked
0 in discussion
0 accepted
2 in progress
0 *mitigated*
0 *false positive*



Threat model for an Obsidian TypeScript plugin that sends selected note text to ElevenLabs API and writes generated MP3 files into the vault.

Impact Analysis of 16 Initial Risks in 15 Categories

The most prevalent impacts of the **16 initial risks** (distributed over **15 risk categories**) are (taking the severity ratings into account and using the highest for each category):
Risk finding paragraphs are clickable and link to the corresponding chapter.

Critical: **T1 API Key Plaintext in data.json**: 1 Initial Risk - Exploitation likelihood is *Likely* with *High* impact.
Theft of API key can enable unauthorized API usage, billing abuse, and lateral misuse.

High: **T3 Audio Output Path Traversal**: 1 Initial Risk - Exploitation likelihood is *Likely* with *High* impact.
Overwrite or create arbitrary files in the vault and potentially in adjacent filesystem paths.

High: **T8 API Key Leakage in Logs**: 1 Initial Risk - Exploitation likelihood is *Likely* with *High* impact.
Secrets become retrievable by local users, malware, debugging collectors, or log forwarding sinks.

Elevated: **Missing Cloud Hardening**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Very High* impact.
If this risk is unmitigated, attackers might access cloud components in an unintended way.

Elevated: **Missing File Validation**: 1 Initial Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to provide malicious files to the application.

Elevated: **Missing Hardening**: 1 Initial Risk - Exploitation likelihood is *Likely* with *Medium* impact.
If this risk remains unmitigated, attackers might be able to easier attack high-value targets.

Elevated: **Path-Traversal**: 1 Initial Risk - Exploitation likelihood is *Likely* with *High* impact.
If this risk is unmitigated, attackers might be able to read sensitive files (configuration data, key/credential files, deployment files, business data files, etc.) from the filesystem of affected components.

Elevated: **Unguarded Access From Internet**: 1 Initial Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to directly attack sensitive systems without any hardening components in-between due to them being directly exposed on the internet.

Medium: **Missing Build Infrastructure**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model due to critical build infrastructure components missing in the model.

Medium: **Missing Identity Store**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model in the identity provider/store that is currently missing in the model.

Medium: **Missing Network Segmentation**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards more valuable targets, as they are not separated by network segmentation.

Medium: **Missing Two-Factor Authentication (2FA)**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to access or modify highly sensitive data without strong authentication.

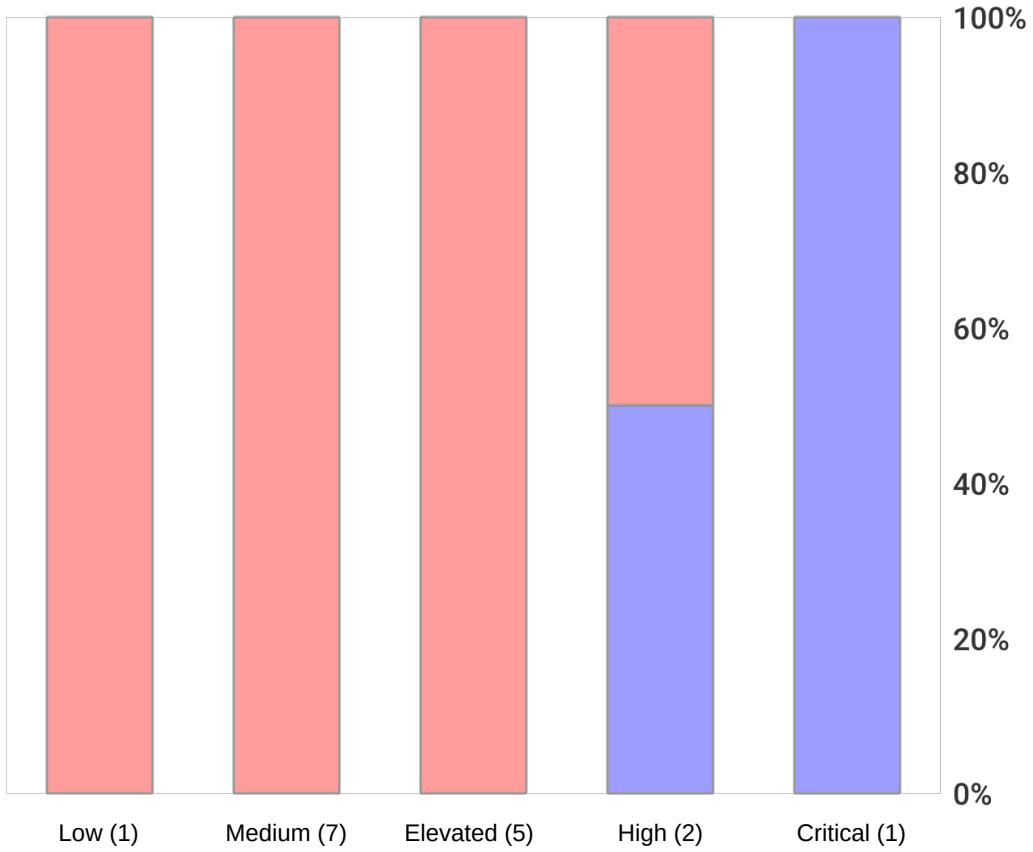
Medium: **Missing Vault (Secret Storage)**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to easier steal config secrets (like credentials, private keys, client certificates, etc.) once a vulnerability to access files is present and exploited.

Medium: **Unencrypted Technical Assets**: 2 Initial Risks - Exploitation likelihood is *Unlikely* with *High* impact.
If this risk is unmitigated, attackers might be able to access unencrypted data when successfully compromising sensitive components.

Low: **Wrong Communication Link Content**: 1 Initial Risk - Exploitation likelihood is *Unlikely* with *Low* impact.
If this potential model error is not fixed, some risks might not be visible.

Risk Mitigation

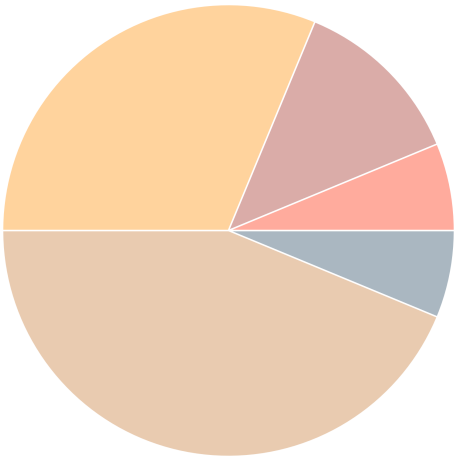
The following chart gives a high-level overview of the risk tracking status (including mitigated risks):



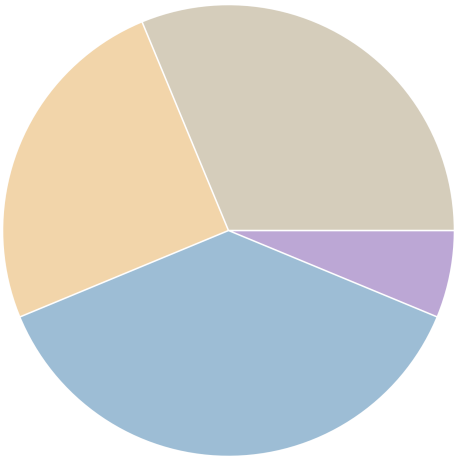
14 unchecked
0 in discussion
0 accepted
2 in progress
0 *mitigated*
0 *false positive*

After removal of risks with status *mitigated* and *false positive* the following **16 remain unmitigated**:

1 unmitigated critical risk
2 unmitigated high risk
5 unmitigated elevated risk
7 unmitigated medium risk
1 unmitigated low risk



1 business side related
6 architecture related
4 development related
5 operations related



Impact Analysis of 16 Remaining Risks in 15 Categories

The most prevalent impacts of the **16 remaining risks** (distributed over **15 risk categories**) are (taking the severity ratings into account and using the highest for each category):
Risk finding paragraphs are clickable and link to the corresponding chapter.

Critical: **T1 API Key Plaintext in data.json**: 1 Remaining Risk - Exploitation likelihood is *Likely* with *High* impact.
Theft of API key can enable unauthorized API usage, billing abuse, and lateral misuse.

High: **T3 Audio Output Path Traversal**: 1 Remaining Risk - Exploitation likelihood is *Likely* with *High* impact.
Overwrite or create arbitrary files in the vault and potentially in adjacent filesystem paths.

High: **T8 API Key Leakage in Logs**: 1 Remaining Risk - Exploitation likelihood is *Likely* with *High* impact.
Secrets become retrievable by local users, malware, debugging collectors, or log forwarding sinks.

Elevated: **Missing Cloud Hardening**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Very High* impact.
If this risk is unmitigated, attackers might access cloud components in an unintended way.

Elevated: **Missing File Validation**: 1 Remaining Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to provide malicious files to the application.

Elevated: **Missing Hardening**: 1 Remaining Risk - Exploitation likelihood is *Likely* with *Medium* impact.
If this risk remains unmitigated, attackers might be able to easier attack high-value targets.

Elevated: **Path-Traversal**: 1 Remaining Risk - Exploitation likelihood is *Likely* with *High* impact.
If this risk is unmitigated, attackers might be able to read sensitive files (configuration data, key/credential files, deployment files, business data files, etc.) from the filesystem of affected components.

Elevated: **Unguarded Access From Internet**: 1 Remaining Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to directly attack sensitive systems without any hardening components in-between due to them being directly exposed on the internet.

Medium: **Missing Build Infrastructure**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model due to critical build infrastructure components missing in the model.

Medium: **Missing Identity Store**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model in the identity provider/store that is currently missing in the model.

Medium: **Missing Network Segmentation**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards more valuable targets, as they are not separated by network segmentation.

Medium: **Missing Two-Factor Authentication (2FA)**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to access or modify highly sensitive data without strong authentication.

Medium: **Missing Vault (Secret Storage)**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
If this risk is unmitigated, attackers might be able to easier steal config secrets (like credentials, private keys, client certificates, etc.) once a vulnerability to access files is present and exploited.

Medium: **Unencrypted Technical Assets**: 2 Remaining Risks - Exploitation likelihood is *Unlikely* with *High* impact.
If this risk is unmitigated, attackers might be able to access unencrypted data when successfully compromising sensitive components.

Low: **Wrong Communication Link Content**: 1 Remaining Risk - Exploitation likelihood is *Unlikely* with *Low* impact.
If this potential model error is not fixed, some risks might not be visible.

Application Overview

Business Criticality

The overall business criticality of "Obsidian TTS" was rated as:

(archive | operational | **IMPORTANT** | critical | mission-critical)

Business Overview

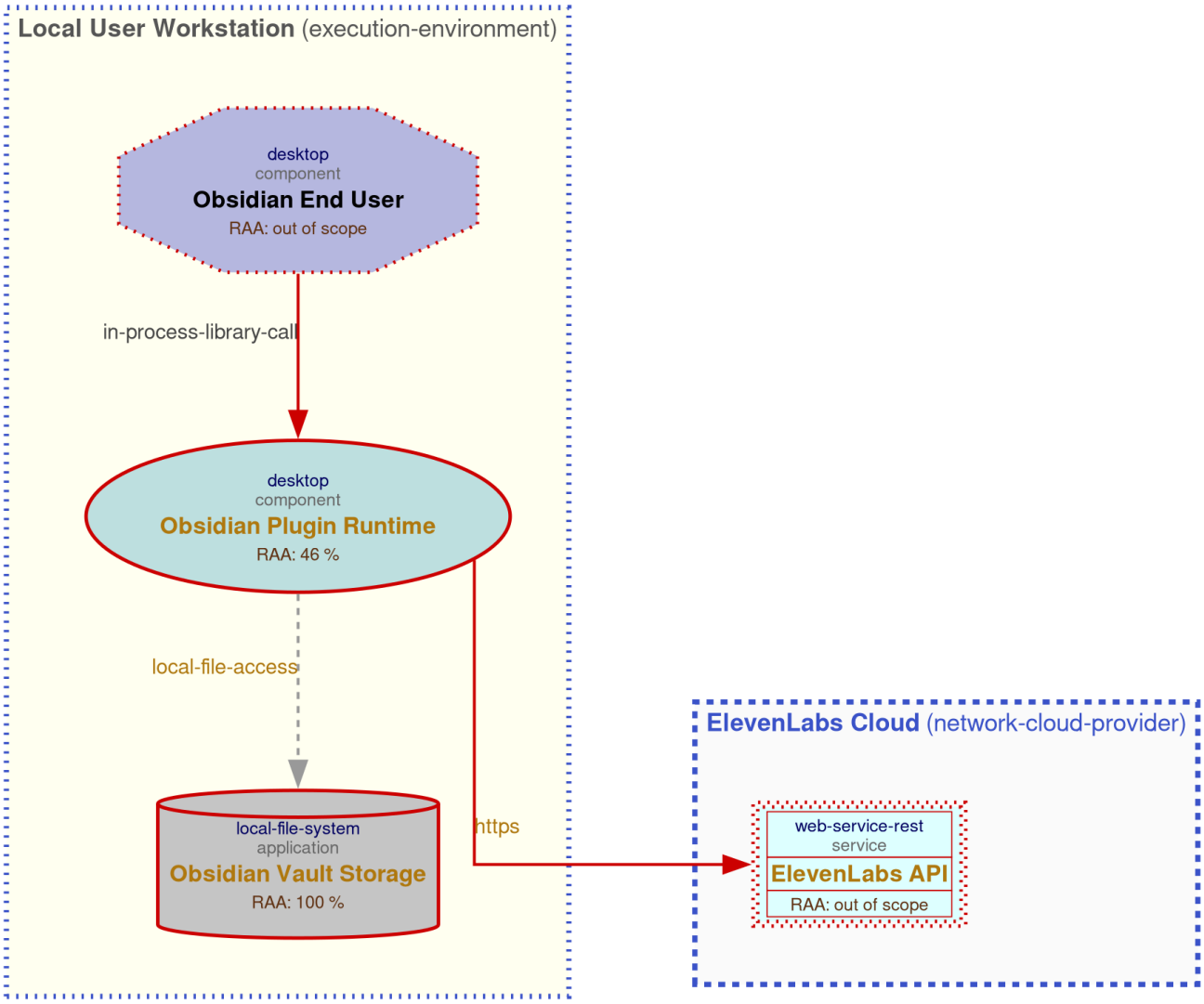
The plugin converts user-selected text from notes into audio using ElevenLabs and stores resulting MP3 files in the local vault.

Technical Overview

Main flow: Obsidian user -> plugin runtime -> ElevenLabs API (HTTPS) -> plugin writes MP3 to local vault.

Data-Flow Diagram

The following diagram was generated by Threagile based on the model input and gives a high-level overview of the data-flow between technical assets. The RAA value is the calculated *Relative Attacker Attractiveness* in percent. For a full high-resolution version of this diagram please refer to the PNG image file alongside this report.



Security Requirements

This chapter lists the custom security requirements which have been defined for the modeled target.

Input and Path Validation
Output paths and filenames must be validated and normalized.

Protect Secrets at Rest
API keys must not be stored in plaintext without compensating controls.

Secret-Safe Logging
Logging must redact secrets and sensitive request metadata.

This list is not complete and regulatory or law relevant security requirements have to be taken into account as well. Also custom individual security requirements might exist for the project.

Abuse Cases

This chapter lists the custom abuse cases which have been defined for the modeled target.

API Key Theft
As an attacker I want to obtain the ElevenLabs API key from local settings or logs to abuse the account.

Sensitive Data Exfiltration
As an attacker I want to exfiltrate sensitive note content via API requests or generated artifacts.

Vault Path Traversal
As an attacker I want to control output paths and overwrite unintended files in the vault.

This list is not complete and regulatory or law relevant abuse cases have to be taken into account as well. Also custom individual abuse cases might exist for the project.

Tag Listing

This chapter lists what tags are used by which elements.

desktop
Local User Workstation

elevenlabs
ElevenLabs API, ElevenLabs TTS API Call, ElevenLabs API Key, Generated Audio Files, ElevenLabs Cloud

obsidian
Obsidian End User, Obsidian Vault Storage, Generated Audio Files, Obsidian Plugin Settings, Selected Note Text

plugin
Obsidian Plugin Runtime, Obsidian Plugin Settings, Plugin Execution Logs

typescript
Obsidian Plugin Runtime

vault
Obsidian Vault Storage

STRIDE Classification of Identified Risks

This chapter clusters and classifies the risks by STRIDE categories: In total **16 potential risks** have been identified during the threat modeling process of which **2 in the Spoofing** category, **4 in the Tampering** category, **0 in the Repudiation** category, **7 in the Information Disclosure** category, **0 in the Denial of Service** category, and **3 in the Elevation of Privilege** category.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Spoofing

Elevated: **Missing File Validation**: 1 / 1 Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
When a technical asset accepts files, these input files should be strictly validated about filename and type.

Medium: **Missing Identity Store**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Tampering

High: **T3 Audio Output Path Traversal**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
Unsanitized output paths can allow traversal beyond intended vault location.

Elevated: **Missing Cloud Hardening**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Very High* impact.
Cloud components should be hardened according to the cloud vendor best practices. This affects their configuration, auditing, and further areas.

Elevated: **Missing Hardening**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *Medium* impact.
Technical assets with a Relative Attacker Attractiveness (RAA) value of 55 % or higher should be explicitly hardened taking best practices and vendor hardening guides into account.

Medium: **Missing Build Infrastructure**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Repudiation

n/a

Information Disclosure

Critical: **T1 API Key Plaintext in data.json**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
API key is stored unencrypted in Obsidian plugin settings (`data.json`).

High: **T8 API Key Leakage in Logs**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
API key or sensitive authorization metadata might be emitted into plugin logs/console.

Elevated: **Path-Traversal**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
When a filesystem is accessed Path-Traversal or Local-File-Inclusion (LFI) risks might arise. The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed or stored.

Medium: **Missing Vault (Secret Storage)**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Medium: **Unencrypted Technical Assets**: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *High* impact.
Due to the confidentiality rating of the technical asset itself and/or the processed data assets this technical asset must be encrypted. The risk rating depends on the sensitivity technical asset itself and of the data assets stored.

Low: **Wrong Communication Link Content**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Low* impact.
When a communication link is defined as readonly, but does not receive any data asset, or when it is defined as not readonly, but does not send any data asset, it is likely to be a model failure.

Denial of Service

n/a

Elevation of Privilege

Elevated: **Unguarded Access From Internet**: 1 / 1 Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
Internet-exposed assets must be guarded by a protecting service, application, or reverse-proxy.

Medium: **Missing Network Segmentation**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Highly sensitive assets and/or datastores residing in the same network segment than other lower sensitive assets (like webservers or content management systems etc.) should be better protected by a network segmentation trust-boundary.

Medium: **Missing Two-Factor Authentication (2FA)**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Technical assets (especially multi-tenant systems) should authenticate incoming requests with two-factor (2FA) authentication when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by humans.

Assignment by Function

This chapter clusters and assigns the risks by functions which are most likely able to check and mitigate them: In total **16 potential risks** have been identified during the threat modeling process of which **1 should be checked by Business Side**, **6 should be checked by Architecture**, **4 should be checked by Development**, and **5 should be checked by Operations**.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Business Side

Medium: **Missing Two-Factor Authentication (2FA)**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Apply an authentication method to the technical asset protecting highly sensitive data via two-factor authentication for human users.

Architecture

Critical: **T1 API Key Plaintext in data.json**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
Migrate API key storage from `data.json` to keychain-backed storage and scrub legacy values.

Elevated: **Unguarded Access From Internet**: 1 / 1 Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
Encapsulate the asset behind a guarding service, application, or reverse-proxy. For admin maintenance a bastion-host should be used as a jump-server. For file transfer a store-and-forward-host should be used as an indirect file exchange platform.

Medium: **Missing Build Infrastructure**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Include the build infrastructure in the model.

Medium: **Missing Identity Store**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Include an identity store in the model if the application has a login.

Medium: **Missing Vault (Secret Storage)**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Consider using a Vault (Secret Storage) to securely store and access config secrets (like credentials, private keys, client certificates, etc.).

Low: **Wrong Communication Link Content**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Low* impact.
Try to model the correct readonly flag and/or data sent/received of communication links. Also try to use communication link types matching the target technology/machine types.

Development

High: **T3 Audio Output Path Traversal**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
Enforce normalized allowlisted path segments and reject traversal patterns (`..`, absolute paths, mixed separators).

High: **T8 API Key Leakage in Logs**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
Centralized logger with redaction patterns and secure debug-mode gating.

Elevated: **Missing File Validation**: 1 / 1 Risk - Exploitation likelihood is *Very Likely* with *Medium* impact.
Filter by file extension and discard (if feasible) the name provided. Whitelist the accepted file types and determine the mime-type on the server-side (for example via "Apache Tika" or similar checks). If the file is retrievable by endusers and/or backoffice employees, consider performing scans for popular malware (if the files can be retrieved much later than they were uploaded, also apply a fresh malware scan during retrieval to scan with newer signatures of popular malware). Also enforce limits on maximum file size to avoid denial-of-service like scenarios.

Elevated: **Path-Traversal**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *High* impact.
Before accessing the file cross-check that it resides in the expected folder and is of the expected type and filename/suffix. Try to use a mapping if possible instead of directly accessing by a filename which is (partly or fully) provided by the caller. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

Operations

Elevated: **Missing Cloud Hardening**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Very High* impact.
Apply hardening of all cloud components and services, taking special care to follow the individual risk descriptions (which depend on the cloud provider tags in the model).

Elevated: **Missing Hardening**: 1 / 1 Risk - Exploitation likelihood is *Likely* with *Medium* impact.
Try to apply all hardening best practices (like CIS benchmarks, OWASP recommendations, vendor recommendations, DevSec Hardening Framework, DBSAT for Oracle databases, and others).

Medium: **Missing Network Segmentation**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.
Apply a network segmentation trust-boundary around the highly sensitive assets and/or datastores.

Medium: **Unencrypted Technical Assets**: 2 / 2 Risks - Exploitation likelihood is *Unlikely* with *High* impact.
Apply encryption to the technical asset.

RAA Analysis

For each technical asset the **"Relative Attacker Attractiveness"** (RAA) value was calculated in percent. The higher the RAA, the more interesting it is for an attacker to compromise the asset. The calculation algorithm takes the sensitivity ratings and quantities of stored and processed data into account as well as the communication links of the technical asset. Neighbouring assets to high-value RAA targets might receive an increase in their RAA value when they have a communication link towards that target ("Pivoting-Factor").

The following lists all technical assets sorted by their RAA value from highest (most attacker attractive) to lowest. This list can be used to prioritize on efforts relevant for the most attacker-attractive technical assets:

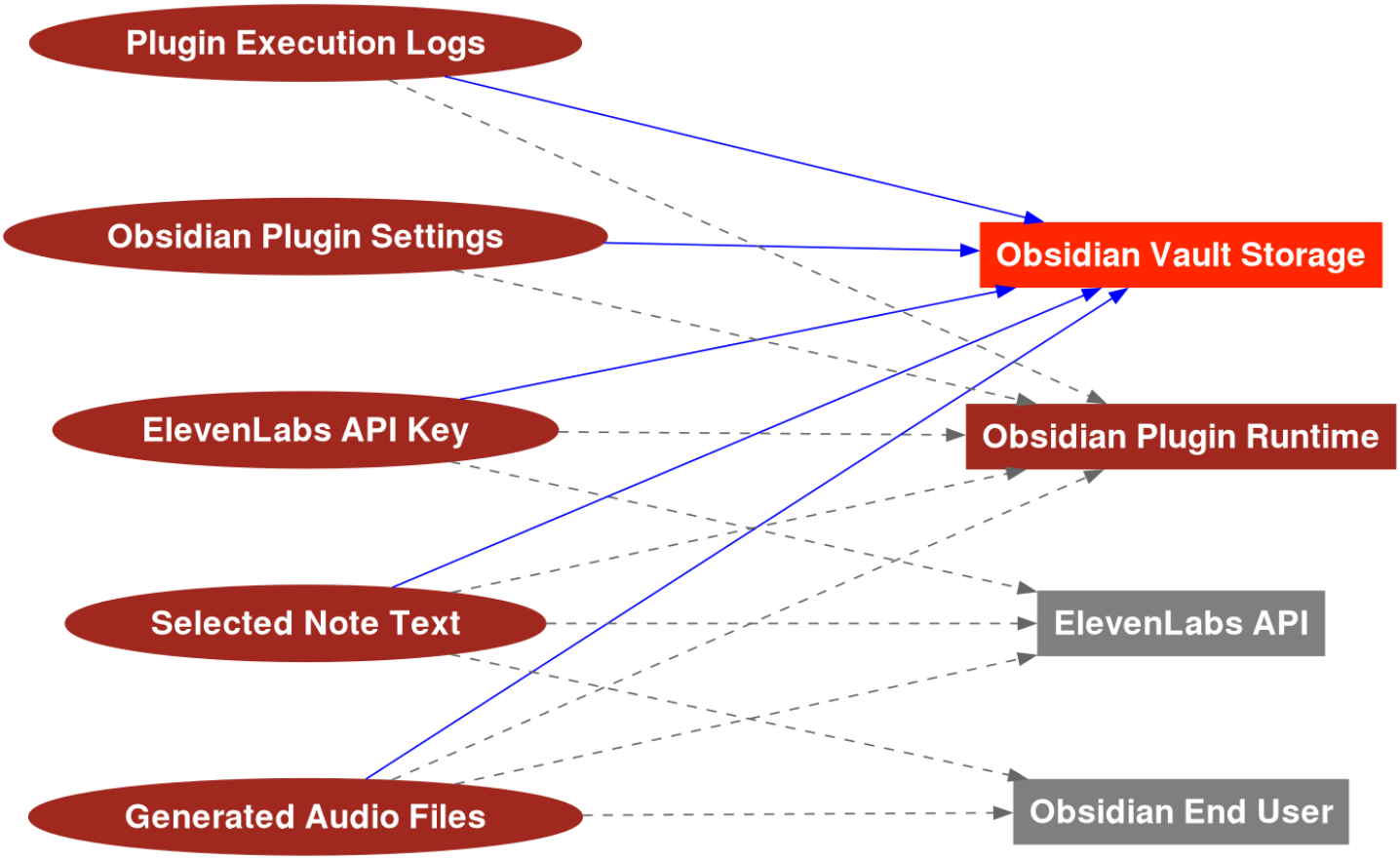
Technical asset paragraphs are clickable and link to the corresponding chapter.

Obsidian Vault Storage: RAA 100%
Local vault filesystem containing notes, plugin data.json settings, and generated MP3 files.

Obsidian Plugin Runtime: RAA 46%
TypeScript plugin logic running in Obsidian desktop runtime.

Data Mapping

The following diagram was generated by Threagile based on the model input and gives a high-level distribution of data assets across technical assets. The color matches the identified data breach probability and risk level (see the "Data Breach Probabilities" chapter for more details). A solid line stands for *data is stored by the asset* and a dashed one means *data is processed by the asset*. For a full high-resolution version of this diagram please refer to the PNG image file alongside this report.



Out-of-Scope Assets: 2 Assets

This chapter lists all technical assets that have been defined as out-of-scope. Each one should be checked in the model whether it should better be included in the overall risk analysis:

Technical asset paragraphs are clickable and link to the corresponding chapter.

ElevenLabs API: out-of-scope
Third-party SaaS managed by ElevenLabs.

Obsidian End User: out-of-scope
Human actor operating the local Obsidian application.

Potential Model Failures: 4 / 4 Risks

This chapter lists potential model failures where not all relevant assets have been modeled or the model might itself contain inconsistencies. Each potential model failure should be checked in the model against the architecture design:

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium: **Missing Build Infrastructure**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Medium: **Missing Identity Store**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Medium: **Missing Vault (Secret Storage)**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Medium* impact.

In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Low: **Wrong Communication Link Content**: 1 / 1 Risk - Exploitation likelihood is *Unlikely* with *Low* impact.

When a communication link is defined as readonly, but does not receive any data asset, or when it is defined as not readonly, but does not send any data asset, it is likely to be a model failure.

Questions: 3 / 3 Questions

This chapter lists custom questions that arose during the threat modeling process.

How are plugin logs protected from secret leakage?
- answer pending -

How are user endpoints managed/protected against compromise?
- answer pending -

How is plugin setting storage (including API key) hardened?
- answer pending -

Identified Risks by Vulnerability Category

In total **16 potential risks** have been identified during the threat modeling process of which **1 are rated as critical**, **2 as high**, **5 as elevated**, **7 as medium**, and **1 as low**.

These risks are distributed across **15 vulnerability categories**. The following sub-chapters of this section describe each identified risk category.

T1 API Key Plaintext in data.json: 1 / 1 Risk

Description (Information Disclosure): CWE 312

API key is stored unencrypted in Obsidian plugin settings (`data.json`).

Impact

Theft of API key can enable unauthorized API usage, billing abuse, and lateral misuse.

Detection Logic

Search local plugin settings for key patterns and verify keychain integration paths.

Risk Rating

High likelihood on compromised endpoints with high exploitation impact.

False Positives

Placeholder tokens or empty key fields might be misdetected as secrets.

Mitigation (Architecture): Avoid plaintext secret persistence; use OS keychain or encrypted-at-rest storage with access controls.

Migrate API key storage from `data.json` to keychain-backed storage and scrub legacy values.

ASVS Chapter: V6 - Stored Cryptography
Cheat Sheet: Secrets_Management_Cheat_Sheet

Check

Verify no plaintext API key remains in vault `.obsidian/plugins/*/data.json` files.

Risk Findings

The risk **T1 API Key Plaintext in data.json** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Critical Risk Severity

API key persisted plaintext in local vault settings: Exploitation likelihood is *Likely* with *High* impact.

t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

in Progress 2026-03-09 vonst T1

Migration from plaintext `data.json` secret storage to safer storage is in progress.

T3 Audio Output Path Traversal: 1 / 1 Risk

Description (Tampering): CWE 22

Unsanitized output paths can allow traversal beyond intended vault location.

Impact

Overwrite or create arbitrary files in the vault and potentially in adjacent filesystem paths.

Detection Logic

Fuzz output path inputs with traversal payloads and assert blocked writes.

Risk Rating

Likelihood depends on attacker control over filename/path inputs; impact is high when writes are unconstrained.

False Positives

Legitimate nested relative paths inside the vault can resemble traversal attempts.

Mitigation (Development): Canonicalize and validate output paths against vault root before write operations.

Enforce normalized allowlisted path segments and reject traversal patterns (`..`, absolute paths, mixed separators).

ASVS Chapter: V5 - Validation, Sanitization and Encoding
Cheat Sheet: Input_Validation_Cheat_Sheet

Check

Unit and integration tests prove writes are constrained to vault root on all supported platforms.

Risk Findings

The risk **T3 Audio Output Path Traversal** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

Potential traversal in mp3 vault write path: Exploitation likelihood is *Likely* with *High* impact.

t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

in Progress 2026-03-09 vonst T3

Path canonicalization and vault-root enforcement are being implemented.

T8 API Key Leakage in Logs: 1 / 1 Risk

Description (Information Disclosure): CWE 532

API key or sensitive authorization metadata might be emitted into plugin logs/console.

Impact

Secrets become retrievable by local users, malware, debugging collectors, or log forwarding sinks.

Detection Logic

Static and runtime checks for logging sinks containing `apiKey`, `Authorization`, or known token formats.

Risk Rating

Common during troubleshooting paths; impact remains high if secrets are exposed.

False Positives

Masked or synthetic test keys may trigger simple detectors.

Mitigation (Development): Redact secrets and prohibit logging of authorization headers and raw config blobs.

Centralized logger with redaction patterns and secure debug-mode gating.

ASVS Chapter: V9 - Communications
Cheat Sheet: Logging_Cheat_Sheet

Check

Automated tests assert log output never contains key patterns or auth header values.

Risk Findings

The risk **T8 API Key Leakage in Logs** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

Sensitive auth material written to plugin logs: Exploitation likelihood is *Likely* with *High* impact.
t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Unchecked

Missing Cloud Hardening: 1 / 1 Risk

Description (Tampering): CWE 1008

Cloud components should be hardened according to the cloud vendor best practices. This affects their configuration, auditing, and further areas.

Impact

If this risk is unmitigated, attackers might access cloud components in an unintended way.

Detection Logic

In-scope cloud components (either residing in cloud trust boundaries or more specifically tagged with cloud provider types).

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

False Positives

Cloud components not running parts of the target architecture can be considered as false positives after individual review.

Mitigation (Operations): Cloud Hardening

Apply hardening of all cloud components and services, taking special care to follow the individual risk descriptions (which depend on the cloud provider tags in the model).

For **Amazon Web Services (AWS)**: Follow the *CIS Benchmark for Amazon Web Services* (see also the automated checks of cloud audit tools like *"PacBot", "CloudSploit", "CloudMapper", "ScoutSuite", or "Prowler AWS CIS Benchmark Tool"*).
For EC2 and other servers running Amazon Linux, follow the *CIS Benchmark for Amazon Linux* and switch to IMDSv2.
For S3 buckets follow the *Security Best Practices for Amazon S3* at https://docs.aws.amazon.com/AmazonS3/latest/dev/security-best-practices.html to avoid accidental leakage.
Also take a look at some of these tools: https://github.com/toniblyx/my-arsenal-of-aws-security-tools

For **Microsoft Azure**: Follow the *CIS Benchmark for Microsoft Azure* (see also the automated checks of cloud audit tools like *"CloudSploit" or "ScoutSuite"*).

For **Google Cloud Platform**: Follow the *CIS Benchmark for Google Cloud Computing Platform* (see also the automated checks of cloud audit tools like *"CloudSploit" or "ScoutSuite"*).

For **Oracle Cloud Platform**: Follow the hardening best practices (see also the automated checks of cloud audit tools like *"CloudSploit"*).

ASVS Chapter: V1 - Architecture, Design and Threat Modeling Requirements
Cheat Sheet: Attack_Surface_Analysis_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Cloud Hardening** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Cloud Hardening risk at **ElevenLabs Cloud**: Exploitation likelihood is *Unlikely* with *Very High* impact.
missing-cloud-hardening@elevenlabs-cloud

Unchecked

Missing File Validation: 1 / 1 Risk

Description (Spoofing): CWE 434

When a technical asset accepts files, these input files should be strictly validated about filename and type.

Impact

If this risk is unmitigated, attackers might be able to provide malicious files to the application.

Detection Logic

In-scope technical assets with custom-developed code accepting file data formats.

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

False Positives

Fully trusted (i.e. cryptographically signed or similar) files can be considered as false positives after individual review.

Mitigation (Development): File Validation

Filter by file extension and discard (if feasible) the name provided. Whitelist the accepted file types and determine the mime-type on the server-side (for example via "Apache Tika" or similar checks). If the file is retrievable by endusers and/or backoffice employees, consider performing scans for popular malware (if the files can be retrieved much later than they were uploaded, also apply a fresh malware scan during retrieval to scan with newer signatures of popular malware). Also enforce limits on maximum file size to avoid denial-of-service like scenarios.

ASVS Chapter: V12 - File and Resources Verification Requirements
Cheat Sheet: File_Upload_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing File Validation** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing File Validation risk at **Obsidian Plugin Runtime**: Exploitation likelihood is *Very Likely* with *Medium* impact.
missing-file-validation@obsidian-plugin-runtime

Unchecked

Missing Hardening: 1 / 1 Risk

Description (Tampering): CWE 16

Technical assets with a Relative Attacker Attractiveness (RAA) value of 55 % or higher should be explicitly hardened taking best practices and vendor hardening guides into account.

Impact

If this risk remains unmitigated, attackers might be able to easier attack high-value targets.

Detection Logic

In-scope technical assets with RAA values of 55 % or higher. Generally for high-value targets like datastores, application servers, identity providers and ERP systems this limit is reduced to 40 %

Risk Rating

The risk rating depends on the sensitivity of the data processed or stored in the technical asset.

False Positives

Usually no false positives.

Mitigation (Operations): System Hardening

Try to apply all hardening best practices (like CIS benchmarks, OWASP recommendations, vendor recommendations, DevSec Hardening Framework, DBSAT for Oracle databases, and others).

ASVS Chapter: V14 - Configuration Verification Requirements
Cheat Sheet: Attack_Surface_Analysis_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Hardening** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Missing Hardening risk at **Obsidian Vault Storage**: Exploitation likelihood is *Likely* with *Medium* impact.
missing-hardening@obsidian-vault-storage

Unchecked

Path-Traversal: 1 / 1 Risk

Description (Information Disclosure): CWE 22

When a filesystem is accessed Path-Traversal or Local-File-Inclusion (LFI) risks might arise. The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed or stored.

Impact

If this risk is unmitigated, attackers might be able to read sensitive files (configuration data, key/credential files, deployment files, business data files, etc.) from the filesystem of affected components.

Detection Logic

Filesystems accessed by in-scope callers.

Risk Rating

The risk rating depends on the sensitivity of the data stored inside the technical asset.

False Positives

File accesses by filenames not consisting of parts controllable by the caller can be considered as false positives after individual review.

Mitigation (Development): Path-Traversal Prevention

Before accessing the file cross-check that it resides in the expected folder and is of the expected type and filename/suffix. Try to use a mapping if possible instead of directly accessing by a filename which is (partly or fully) provided by the caller. When a third-party product is used instead of custom developed software, check if the product applies the proper mitigation and ensure a reasonable patch-level.

ASVS Chapter: V12 - File and Resources Verification Requirements
Cheat Sheet: Input_Validation_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Path-Traversal** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Path-Traversal risk at **Obsidian Plugin Runtime** against filesystem **Obsidian Vault Storage** via **Read or Write Vault Files**: Exploitation likelihood is *Likely* with *High* impact.

path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Unchecked

Unguarded Access From Internet: 1 / 1 Risk

Description (Elevation of Privilege): CWE 501

Internet-exposed assets must be guarded by a protecting service, application, or reverse-proxy.

Impact

If this risk is unmitigated, attackers might be able to directly attack sensitive systems without any hardening components in-between due to them being directly exposed on the internet.

Detection Logic

In-scope technical assets (excluding load-balancer) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) when accessed directly from the internet. All web-server, web-application, reverse-proxy, waf, and gateway assets are exempted from this risk when they do not consist of custom developed code and the data-flow only consists of HTTP or FTP protocols. Access from monitoring systems as well as VPN-protected connections are exempted.

Risk Rating

The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

False Positives

When other means of filtering client requests are applied equivalent of reverse-proxy, waf, or gateway components.

Mitigation (Architecture): Encapsulation of Technical Asset

Encapsulate the asset behind a guarding service, application, or reverse-proxy. For admin maintenance a bastion-host should be used as a jump-server. For file transfer a store-and-forward-host should be used as an indirect file exchange platform.

ASVS Chapter: V1 - Architecture, Design and Threat Modeling Requirements
Cheat Sheet: Attack_Surface_Analysis_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Unguarded Access From Internet** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Elevated Risk Severity

Unguarded Access from Internet of **Obsidian Vault Storage** by **Obsidian Plugin Runtime** via **Read or Write Vault Files**: Exploitation likelihood is *Very Likely* with *Medium* impact.
unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Unchecked

Missing Build Infrastructure: 1 / 1 Risk

Description (Tampering): CWE 1127

The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Impact

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model due to critical build infrastructure components missing in the model.

Detection Logic

Models with in-scope custom-developed parts missing in-scope development (code creation) and build infrastructure components (devops-client, sourcecode-repo, build-pipeline, etc.).

Risk Rating

The risk rating depends on the highest sensitivity of the in-scope assets running custom-developed parts.

False Positives

Models not having any custom-developed parts can be considered as false positives after individual review.

Mitigation (Architecture): Build Pipeline Hardening

Include the build infrastructure in the model.

ASVS Chapter: V1 - Architecture, Design and Threat Modeling Requirements
Cheat Sheet: Attack_Surface_Analysis_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Build Infrastructure** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Build Infrastructure in the threat model (referencing asset **Obsidian Plugin Runtime** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.
missing-build-infrastructure@obsidian-plugin-runtime

Unchecked

Missing Identity Store: 1 / 1 Risk

Description (Spoofing): CWE 287

The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Impact

If this risk is unmitigated, attackers might be able to exploit risks unseen in this threat model in the identity provider/store that is currently missing in the model.

Detection Logic

Models with authenticated data-flows authorized via enduser-identity missing an in-scope identity store.

Risk Rating

The risk rating depends on the sensitivity of the enduser-identity authorized technical assets and their data assets processed and stored.

False Positives

Models only offering data/services without any real authentication need can be considered as false positives after individual review.

Mitigation (Architecture): Identity Store

Include an identity store in the model if the application has a login.

ASVS Chapter: V2 - Authentication Verification Requirements
Cheat Sheet: Authentication_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Identity Store** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Identity Store in the threat model (referencing asset **Obsidian Plugin Runtime** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-identity-store@obsidian-plugin-runtime

Unchecked

Missing Network Segmentation: 1 / 1 Risk

Description (Elevation of Privilege): CWE 1008

Highly sensitive assets and/or datastores residing in the same network segment than other lower sensitive assets (like webservers or content management systems etc.) should be better protected by a network segmentation trust-boundary.

Impact

If this risk is unmitigated, attackers successfully attacking other components of the system might have an easy path towards more valuable targets, as they are not separated by network segmentation.

Detection Logic

In-scope technical assets with high sensitivity and RAA values as well as datastores when surrounded by assets (without a network trust-boundary in-between) which are of type client-system, web-server, web-application, cms, web-service-rest, web-service-soap, build-pipeline, sourcecode-repository, monitoring, or similar and there is no direct connection between these (hence no requirement to be so close to each other).

Risk Rating

Default is low risk. The risk is increased to medium when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

False Positives

When all assets within the network segmentation trust-boundary are hardened and protected to the same extend as if all were containing/processing highly sensitive data.

Mitigation (Operations): Network Segmentation

Apply a network segmentation trust-boundary around the highly sensitive assets and/or datastores.

ASVS Chapter: V1 - Architecture, Design and Threat Modeling Requirements
Cheat Sheet: Attack_Surface_Analysis_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Network Segmentation** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Network Segmentation to further encapsulate and protect **Obsidian Vault Storage** against unrelated lower protected assets in the same network segment, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-network-segmentation@obsidian-vault-storage

Unchecked

Missing Two-Factor Authentication (2FA): 1 / 1 Risk

Description (Elevation of Privilege): CWE 308

Technical assets (especially multi-tenant systems) should authenticate incoming requests with two-factor (2FA) authentication when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by humans.

Impact

If this risk is unmitigated, attackers might be able to access or modify highly sensitive data without strong authentication.

Detection Logic

In-scope technical assets (except load-balancer, reverse-proxy, waf, ids, and ips) should authenticate incoming requests via two-factor authentication (2FA) when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by a client used by a human user.

Risk Rating

medium

False Positives

Technical assets which do not process requests regarding functionality or data linked to end-users (customers) can be considered as false positives after individual review.

Mitigation (Business Side): Authentication with Second Factor (2FA)

Apply an authentication method to the technical asset protecting highly sensitive data via two-factor authentication for human users.

ASVS Chapter: V2 - Authentication Verification Requirements
Cheat Sheet: Multifactor_Authentication_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Missing Two-Factor Authentication (2FA)** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Two-Factor Authentication covering communication link **Trigger TTS Command** from **Obsidian End User** to **Obsidian Plugin Runtime**: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Unchecked

Missing Vault (Secret Storage): 1 / 1 Risk

Description (Information Disclosure): CWE 522

In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Impact

If this risk is unmitigated, attackers might be able to easier steal config secrets (like credentials, private keys, client certificates, etc.) once a vulnerability to access files is present and exploited.

Detection Logic

Models without a Vault (Secret Storage).

Risk Rating

The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

False Positives

Models where no technical assets have any kind of sensitive config data to protect can be considered as false positives after individual review.

Mitigation (Architecture): Vault (Secret Storage)

Consider using a Vault (Secret Storage) to securely store and access config secrets (like credentials, private keys, client certificates, etc.).

ASVS Chapter: V6 - Stored Cryptography Verification Requirements
Cheat Sheet: Cryptographic_Storage_Cheat_Sheet

Check

Is a Vault (Secret Storage) in place?

Risk Findings

The risk **Missing Vault (Secret Storage)** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Missing Vault (Secret Storage) in the threat model (referencing asset **Obsidian Vault Storage** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.
missing-vault@obsidian-vault-storage

Unchecked

Unencrypted Technical Assets: 2 / 2 Risks

Description (Information Disclosure): CWE 311

Due to the confidentiality rating of the technical asset itself and/or the processed data assets this technical asset must be encrypted. The risk rating depends on the sensitivity technical asset itself and of the data assets stored.

Impact

If this risk is unmitigated, attackers might be able to access unencrypted data when successfully compromising sensitive components.

Detection Logic

In-scope unencrypted technical assets (excluding reverse-proxy, load-balancer, waf, ids, ips and embedded components like library) storing data assets rated at least as confidential or critical. For technical assets storing data assets rated as strictly-confidential or mission-critical the encryption must be of type data-with-enduser-individual-key.

Risk Rating

Depending on the confidentiality rating of the stored data-assets either medium or high risk.

False Positives

When all sensitive data stored within the asset is already fully encrypted on document or data level.

Mitigation (Operations): Encryption of Technical Asset

Apply encryption to the technical asset.

ASVS Chapter: V6 - Stored Cryptography Verification Requirements
Cheat Sheet: Cryptographic_Storage_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Unencrypted Technical Assets** was found **2 times** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.
Risk finding paragraphs are clickable and link to the corresponding chapter.

Medium Risk Severity

Unencrypted Technical Asset named **Obsidian Plugin Runtime**: Exploitation likelihood is *Unlikely* with *High* impact.
unencrypted-asset@obsidian-plugin-runtime

Unchecked

Unencrypted Technical Asset named **Obsidian Vault Storage** missing enduser-individual encryption with data-with-enduser-individual-key: Exploitation likelihood is *Unlikely* with *High* impact.
unencrypted-asset@obsidian-vault-storage

Unchecked

Wrong Communication Link Content: 1 / 1 Risk

Description (Information Disclosure): CWE 1008

When a communication link is defined as readonly, but does not receive any data asset, or when it is defined as not readonly, but does not send any data asset, it is likely to be a model failure.

Impact

If this potential model error is not fixed, some risks might not be visible.

Detection Logic

Communication links with inconsistent data assets being sent/received not matching their readonly flag or otherwise inconsistent protocols not matching the target technology type.

Risk Rating

low

False Positives

Usually no false positives as this looks like an incomplete model.

Mitigation (Architecture): Model Consistency

Try to model the correct readonly flag and/or data sent/received of communication links. Also try to use communication link types matching the target technology/machine types.

ASVS Chapter: V1 - Architecture, Design and Threat Modeling Requirements
Cheat Sheet: Threat_Modeling_Cheat_Sheet

Check

Are recommendations from the linked cheat sheet and referenced ASVS chapter applied?

Risk Findings

The risk **Wrong Communication Link Content** was found **1 time** in the analyzed architecture to be potentially possible. Each spot should be checked individually by reviewing the implementation whether all controls have been applied properly in order to mitigate each risk.

Risk finding paragraphs are clickable and link to the corresponding chapter.

Low Risk Severity

Wrong Communication Link Content (protocol type "in-process-library-call" does not match target technology type "desktop": expected "library") at **Obsidian End User** regarding communication link **Trigger TTS Command**: Exploitation likelihood is *Unlikely* with *Low* impact.

wrong-communication-link-content@obsidian-end-user@obsidian-end-user>trigger-tts-command

Unchecked

Identified Risks by Technical Asset

In total **16 potential risks** have been identified during the threat modeling process of which **1 are rated as critical**, **2 as high**, **5 as elevated**, **7 as medium**, and **1 as low**.

These risks are distributed across **2 in-scope technical assets**. The following sub-chapters of this section describe each identified risk grouped by technical asset. The RAA value of a technical asset is the calculated "Relative Attacker Attractiveness" value in percent.

Obsidian Vault Storage: 6 / 6 Risks

Description

Local vault filesystem containing notes, plugin data.json settings, and generated MP3 files.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Critical Risk Severity

API key persisted plaintext in local vault settings: Exploitation likelihood is *Likely* with *High* impact.

t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

in Progress 2026-03-09 vonst T1
Migration from plaintext `data.json` secret storage to safer storage is in progress.

Elevated Risk Severity

Unguarded Access from Internet of **Obsidian Vault Storage** by **Obsidian Plugin Runtime** via **Read or Write Vault Files**: Exploitation likelihood is *Very Likely* with *Medium* impact.

unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Unchecked

Missing Hardening risk at **Obsidian Vault Storage**: Exploitation likelihood is *Likely* with *Medium* impact.

missing-hardening@obsidian-vault-storage

Unchecked

Medium Risk Severity

Unencrypted Technical Asset named **Obsidian Vault Storage** missing enduser-individual encryption with data-with-enduser-individual-key: Exploitation likelihood is *Unlikely* with *High* impact.

unencrypted-asset@obsidian-vault-storage

Unchecked

Missing Network Segmentation to further encapsulate and protect **Obsidian Vault Storage** against unrelated lower protected assets in the same network segment, which might be easier to compromise by attackers: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-network-segmentation@obsidian-vault-storage

Unchecked

Missing Vault (Secret Storage) in the threat model (referencing asset **Obsidian Vault Storage** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-vault@obsidian-vault-storage

Unchecked

Asset Information

ID:	obsidian-vault-storage
Type:	datastore
Usage:	business
RAA:	100 %
Size:	application
Technology:	local-file-system
Tags:	obsidian, vault
Internet:	false
Machine:	physical
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	false
Client by Human:	false
Data Processed:	ElevenLabs API Key, Generated Audio Files, Obsidian Plugin Settings, Plugin Execution Logs, Selected Note Text
Data Stored:	ElevenLabs API Key, Generated Audio Files, Obsidian Plugin Settings, Plugin Execution Logs, Selected Note Text
Formats Accepted:	File, JSON

Asset Rating

Owner:	Vault Owner	
Confidentiality:	strictly-confidential	(rated 5 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Stores plaintext plugin settings and API key in data.json and receives generated MP3 files in vault paths.	

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Read or Write Vault Files (incoming)

Local file operations for settings, logs, and generated audio.

Source:	Obsidian Plugin Runtime
Protocol:	local-file-access
Encrypted:	false
Authentication:	none
Authorization:	technical-user
Read-Only:	false
Usage:	devops
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	ElevenLabs API Key, Generated Audio Files, Obsidian Plugin Settings, Plugin Execution Logs
Data Sent:	Obsidian Plugin Settings, Selected Note Text

Obsidian Plugin Runtime: 8 / 8 Risks

Description

TypeScript plugin logic running in Obsidian desktop runtime.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

High Risk Severity

Sensitive auth material written to plugin logs: Exploitation likelihood is *Likely* with *High* impact.

t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Unchecked

Potential traversal in mp3 vault write path: Exploitation likelihood is *Likely* with *High* impact.

t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

in Progress 2026-03-09 vonst T3
Path canonicalization and vault-root enforcement are being implemented.

Elevated Risk Severity

Path-Traversal risk at **Obsidian Plugin Runtime** against filesystem **Obsidian Vault Storage** via **Read or Write Vault Files**: Exploitation likelihood is *Likely* with *High* impact.

path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Unchecked

Missing File Validation risk at **Obsidian Plugin Runtime**: Exploitation likelihood is *Very Likely* with *Medium* impact.

missing-file-validation@obsidian-plugin-runtime

Unchecked

Medium Risk Severity

Unencrypted Technical Asset named **Obsidian Plugin Runtime**: Exploitation likelihood is *Unlikely* with *High* impact.

unencrypted-asset@obsidian-plugin-runtime

Unchecked

Missing Build Infrastructure in the threat model (referencing asset **Obsidian Plugin Runtime** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-build-infrastructure@obsidian-plugin-runtime

Unchecked

Missing Identity Store in the threat model (referencing asset **Obsidian Plugin Runtime** as an example): Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-identity-store@obsidian-plugin-runtime

Unchecked

Missing Two-Factor Authentication covering communication link **Trigger TTS Command** from **Obsidian End User** to **Obsidian Plugin Runtime**: Exploitation likelihood is *Unlikely* with *Medium* impact.

missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Unchecked

Asset Information

ID:	obsidian-plugin-runtime
Type:	process
Usage:	business
RAA:	46 %
Size:	component
Technology:	desktop
Tags:	plugin, typescript
Internet:	true
Machine:	physical
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	true
Client by Human:	false
Data Processed:	ElevenLabs API Key, Generated Audio Files, Obsidian Plugin Settings, Plugin Execution Logs, Selected Note Text
Data Stored:	none
Formats Accepted:	File, JSON

Asset Rating

Owner:	Plugin Maintainer	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Runtime processes selected text and API key, performs external API calls, and writes output files to the vault.	

Outgoing Communication Links: 2

Target technical asset names are clickable and link to the corresponding chapter.

Read or Write Vault Files (outgoing)

Local file operations for settings, logs, and generated audio.

Target:	Obsidian Vault Storage
Protocol:	local-file-access
Encrypted:	false
Authentication:	none
Authorization:	technical-user
Read-Only:	false
Usage:	devops
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	ElevenLabs API Key, Generated Audio Files, Obsidian Plugin Settings, Plugin Execution Logs
Data Received:	Obsidian Plugin Settings, Selected Note Text

ElevenLabs TTS API Call (outgoing)

HTTPS request to synthesize note text into audio using API key.

Target:	ElevenLabs API
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	elevenlabs
VPN:	false
IP-Filtered:	false
Data Sent:	ElevenLabs API Key, Selected Note Text
Data Received:	Generated Audio Files

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

Trigger TTS Command (incoming)

User action triggers plugin command with selected note text.

Source:	Obsidian End User
Protocol:	in-process-library-call
Encrypted:	false
Authentication:	none
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Received:	Selected Note Text
Data Sent:	Generated Audio Files

Obsidian End User: out-of-scope

Description

Human user triggering text-to-speech actions from Obsidian UI.

Identified Risks of Asset

Risk finding paragraphs are clickable and link to the corresponding chapter.

Low Risk Severity

Wrong Communication Link Content (protocol type "in-process-library-call" does not match target technology type "desktop": expected "library") at **Obsidian End User** regarding communication link **Trigger TTS Command**: Exploitation likelihood is *Unlikely* with *Low* impact.

wrong-communication-link-content@obsidian-end-user@obsidian-end-user>trigger-tts-command

Unchecked

Asset Information

ID:	obsidian-end-user
Type:	external-entity
Usage:	business
RAA:	out-of-scope
Size:	component
Technology:	desktop
Tags:	obsidian
Internet:	false
Machine:	physical
Encryption:	none
Multi-Tenant:	false
Redundant:	false
Custom-Developed:	false
Client by Human:	true
Data Processed:	Generated Audio Files, Selected Note Text
Data Stored:	none
Formats Accepted:	File

Asset Rating

Owner:	Vault Owner	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	The user initiates processing and handles potentially sensitive note content in the local desktop environment.	

Asset Out-of-Scope Justification

Human actor operating the local Obsidian application.

Outgoing Communication Links: 1

Target technical asset names are clickable and link to the corresponding chapter.

Trigger TTS Command (outgoing)

User action triggers plugin command with selected note text.

Target:	Obsidian Plugin Runtime
Protocol:	in-process-library-call
Encrypted:	false
Authentication:	none
Authorization:	enduser-identity-propagation
Read-Only:	false
Usage:	business
Tags:	none
VPN:	false
IP-Filtered:	false
Data Sent:	Selected Note Text
Data Received:	Generated Audio Files

ElevenLabs API: out-of-scope

Description

External ElevenLabs text-to-speech REST API.

Identified Risks of Asset

Asset was defined as out-of-scope.

Asset Information

ID:	elevenlabs-api
Type:	external-entity
Usage:	business
RAA:	out-of-scope
Size:	service
Technology:	web-service-rest
Tags:	elevenlabs
Internet:	true
Machine:	virtual
Encryption:	none
Multi-Tenant:	true
Redundant:	true
Custom-Developed:	false
Client by Human:	false
Data Processed:	ElevenLabs API Key, Generated Audio Files, Selected Note Text
Data Stored:	none
Formats Accepted:	JSON

Asset Rating

Owner:	ElevenLabs	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Service receives sensitive note text and returns generated audio; availability directly impacts feature behavior.	

Asset Out-of-Scope Justification

Third-party SaaS managed by ElevenLabs.

Incoming Communication Links: 1

Source technical asset names are clickable and link to the corresponding chapter.

ElevenLabs TTS API Call (incoming)

HTTPS request to synthesize note text into audio using API key.

Source:	Obsidian Plugin Runtime
Protocol:	https
Encrypted:	true
Authentication:	token
Authorization:	technical-user
Read-Only:	false
Usage:	business
Tags:	elevenlabs
VPN:	false
IP-Filtered:	false
Data Received:	ElevenLabs API Key, Selected Note Text
Data Sent:	Generated Audio Files

Identified Data Breach Probabilities by Data Asset

In total **16 potential risks** have been identified during the threat modeling process of which **1 are rated as critical**, **2 as high**, **5 as elevated**, **7 as medium**, and **1 as low**.

These risks are distributed across **5 data assets**. The following sub-chapters of this section describe the derived data breach probabilities grouped by data asset.
Technical asset names and risk IDs are clickable and link to the corresponding chapter.

ElevenLabs API Key: 12 / 12 Risks

API key configured by the user for authentication against ElevenLabs API.

ID:	elevenlabs-api-key	
Usage:	devops	
Quantity:	very-few	
Tags:	elevenlabs	
Origin:	User Configuration	
Owner:	Vault Owner	
Confidentiality:	strictly-confidential	(rated 5 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	operational	(rated 2 in scale of 5)
CIA-Justification:	Exposure directly enables account abuse and potential billing impact. Integrity is critical to prevent misuse or authentication failures.	
Processed by:	ElevenLabs API, Obsidian Plugin Runtime, Obsidian Vault Storage	
Stored by:	Obsidian Vault Storage	
Sent via:	Read or Write Vault Files, ElevenLabs TTS API Call	
Received via:	none	
Data Breach:	**probable**	
Data Breach Risks:	This data asset has data breach potential because of 12 remaining risks:	

Probable: missing-cloud-hardening@elevenlabs-cloud

Probable: missing-file-validation@obsidian-plugin-runtime

Probable: path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Probable: t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Probable: t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

Possible: missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Possible: unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Possible: t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

Improbable: missing-hardening@obsidian-vault-storage

Improbable: missing-network-segmentation@obsidian-vault-storage

Improbable: unencrypted-asset@obsidian-plugin-runtime

Improbable: unencrypted-asset@obsidian-vault-storage

Generated Audio Files: 12 / 12 Risks

MP3 files generated from selected note text and written to the Obsidian vault.

ID:	generated-audio-files	
Usage:	business	
Quantity:	many	
Tags:	elevenlabs, obsidian	
Origin:	ElevenLabs API	
Owner:	Vault Owner	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Audio files may encode sensitive note content. Integrity matters to avoid tampered or mismatched voice output.	
Processed by:	ElevenLabs API, Obsidian End User, Obsidian Plugin Runtime, Obsidian Vault Storage	
Stored by:	Obsidian Vault Storage	
Sent via:	Read or Write Vault Files	
Received via:	Trigger TTS Command, ElevenLabs TTS API Call	
Data Breach:	**probable**	
Data Breach Risks:	This data asset has data breach potential because of 12 remaining risks:	

Probable: missing-cloud-hardening@elevenlabs-cloud

Probable: missing-file-validation@obsidian-plugin-runtime

Probable: path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Probable: t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Probable: t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

Possible: missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Possible: unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Possible: t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

Improbable: missing-hardening@obsidian-vault-storage

Improbable: missing-network-segmentation@obsidian-vault-storage

Improbable: unencrypted-asset@obsidian-plugin-runtime

Improbable: unencrypted-asset@obsidian-vault-storage

Obsidian Plugin Settings: 11 / 11 Risks

Plugin configuration in data.json including model and voice configuration.

ID:	obsidian-plugin-settings	
Usage:	devops	
Quantity:	very-few	
Tags:	obsidian, plugin	
Origin:	Plugin Runtime	
Owner:	Vault Owner	
Confidentiality:	confidential	(rated 4 in scale of 5)
Integrity:	critical	(rated 4 in scale of 5)
Availability:	important	(rated 3 in scale of 5)
CIA-Justification:	Settings influence output path and API interaction behavior. Unauthorized manipulation can lead to unsafe writes or operational abuse.	
Processed by:	Obsidian Plugin Runtime, Obsidian Vault Storage	
Stored by:	Obsidian Vault Storage	
Sent via:	Read or Write Vault Files	
Received via:	Read or Write Vault Files	
Data Breach:	**probable**	
Data Breach Risks:	This data asset has data breach potential because of 11 remaining risks:	

Probable: missing-file-validation@obsidian-plugin-runtime

Probable: path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Probable: t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Probable: t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

Possible: missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Possible: unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Possible: t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

Improbable: missing-hardening@obsidian-vault-storage

Improbable: missing-network-segmentation@obsidian-vault-storage

Improbable: unencrypted-asset@obsidian-plugin-runtime

Improbable: unencrypted-asset@obsidian-vault-storage

Plugin Execution Logs: 11 / 11 Risks

Local runtime and console logs generated by the plugin during execution.

ID:	plugin-execution-logs	
Usage:	devops	
Quantity:	many	
Tags:	plugin	
Origin:	Plugin Runtime	
Owner:	Vault Owner	
Confidentiality:	restricted	(rated 3 in scale of 5)
Integrity:	archive	(rated 1 in scale of 5)
Availability:	archive	(rated 1 in scale of 5)
CIA-Justification:	Logs support debugging but can expose secrets or sensitive content if not redacted (for example API keys).	
Processed by:	Obsidian Plugin Runtime, Obsidian Vault Storage	
Stored by:	Obsidian Vault Storage	
Sent via:	Read or Write Vault Files	
Received via:	none	
Data Breach:	**probable**	
Data Breach Risks:	This data asset has data breach potential because of 11 remaining risks:	

Probable: missing-file-validation@obsidian-plugin-runtime

Probable: path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Probable: t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Probable: t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

Possible: missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Possible: unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Possible: t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

Improbable: missing-hardening@obsidian-vault-storage

Improbable: missing-network-segmentation@obsidian-vault-storage

Improbable: unencrypted-asset@obsidian-plugin-runtime

Improbable: unencrypted-asset@obsidian-vault-storage

Selected Note Text: 12 / 12 Risks

User-selected text from Obsidian notes sent for text-to-speech generation.

ID:	note-selection-text	
Usage:	business	
Quantity:	few	
Tags:	obsidian	
Origin:	Obsidian Vault	
Owner:	Vault Owner	
Confidentiality:	strictly-confidential	(rated 5 in scale of 5)
Integrity:	important	(rated 3 in scale of 5)
Availability:	operational	(rated 2 in scale of 5)
CIA-Justification:	Notes can contain highly sensitive personal or business information. Confidentiality is prioritized, while integrity and availability are important for correct audio generation.	
Processed by:	ElevenLabs API, Obsidian End User, Obsidian Plugin Runtime, Obsidian Vault Storage	
Stored by:	Obsidian Vault Storage	
Sent via:	Trigger TTS Command, ElevenLabs TTS API Call	
Received via:	Read or Write Vault Files	
Data Breach:	**probable**	
Data Breach Risks:	This data asset has data breach potential because of 12 remaining risks:	

Probable: missing-cloud-hardening@elevenlabs-cloud

Probable: missing-file-validation@obsidian-plugin-runtime

Probable: path-traversal@obsidian-plugin-runtime@obsidian-vault-storage@obsidian-plugin-runtime>read-or-write-vault-files

Probable: t8-api-key-logging-leak@obsidian-plugin-runtime@local-user-workstation@elevenlabs-api-key

Probable: t1-api-key-plaintext-data-json@obsidian-vault-storage@local-user-workstation@elevenlabs-api-key

Possible: missing-authentication-second-factor@obsidian-end-user>trigger-tts-command@obsidian-end-user@obsidian-plugin-runtime

Possible: unguarded-access-from-internet@obsidian-vault-storage@obsidian-plugin-runtime@obsidian-plugin-runtime>read-or-write-vault-files

Possible: t3-audio-output-path-traversal@obsidian-plugin-runtime@local-user-workstation@generated-audio-files

Improbable: missing-hardening@obsidian-vault-storage

Improbable: missing-network-segmentation@obsidian-vault-storage

Improbable: unencrypted-asset@obsidian-plugin-runtime

Improbable: unencrypted-asset@obsidian-vault-storage

Trust Boundaries

In total **2 trust boundaries** have been modeled during the threat modeling process.

ElevenLabs Cloud
External cloud environment hosting ElevenLabs API.

ID:	elevenlabs-cloud
Type:	network-cloud-provider
Tags:	elevenlabs
Assets inside:	ElevenLabs API
Boundaries nested:	none

Local User Workstation
Local execution environment of Obsidian desktop app and vault filesystem.

ID:	local-user-workstation
Type:	execution-environment
Tags:	desktop
Assets inside:	Obsidian End User, Obsidian Plugin Runtime, Obsidian Vault Storage
Boundaries nested:	none

Shared Runtimes

In total **0 shared runtime** has been modeled during the threat modeling process.

Risk Rules Checked by Threagile

Threagile Version: 1.0.0
Threagile Build Timestamp: 20240730113903
Threagile Execution Timestamp: 20260309172425
Model Filename: /app/work/threagile.yaml
Model Hash (SHA256): b417c3e08ce8949c317d371520680d2f2592a08679b4ddcb9d0253af9ec03057

Threagile (see https://threagile.io for more details) is an open-source toolkit for agile threat modeling, created by Christian Schneider (https://christian-schneider.net): It allows to model an architecture with its assets in an agile fashion as a YAML file directly inside the IDE. Upon execution of the Threagile toolkit all standard risk rules (as well as individual custom rules if present) are checked against the architecture model. At the time the Threagile toolkit was executed on the model input file the following risk rules were checked:

T1 API Key Plaintext in data.json
t1-api-key-plaintext-data-json

Individual Risk Category

STRIDE: Information Disclosure
Description: API key is stored unencrypted in Obsidian plugin settings (`data.json`).
Detection: Search local plugin settings for key patterns and verify keychain integration paths.
Rating: High likelihood on compromised endpoints with high exploitation impact.

T3 Audio Output Path Traversal
t3-audio-output-path-traversal

Individual Risk Category

STRIDE: Tampering
Description: Unsanitized output paths can allow traversal beyond intended vault location.
Detection: Fuzz output path inputs with traversal payloads and assert blocked writes.
Rating: Likelihood depends on attacker control over filename/path inputs; impact is high when writes are unconstrained.

T8 API Key Leakage in Logs
t8-api-key-logging-leak

Individual Risk Category

STRIDE: Information Disclosure
Description: API key or sensitive authorization metadata might be emitted into plugin logs/console.
Detection: Static and runtime checks for logging sinks containing `apiKey`, `Authorization`, or known token formats.
Rating: Common during troubleshooting paths; impact remains high if secrets are exposed.

Accidental Secret Leak
accidental-secret-leak

STRIDE: Information Disclosure
Description: Sourcecode repositories (including their histories) as well as artifact registries can accidentally contain secrets like checked-in or packaged-in passwords, API tokens, certificates, crypto keys, etc.
Detection: In-scope sourcecode repositories and artifact registries.
Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Code Backdooring
code-backdooring

STRIDE: Tampering
Description: For each build-pipeline component Code Backdooring risks might arise where attackers compromise the build-pipeline in order to let backdoored artifacts be shipped into production. Aside from direct code backdooring this includes backdooring of dependencies and even of more lower-level build infrastructure, like backdooring compilers (similar to what the XcodeGhost malware did) or dependencies.
Detection: In-scope development relevant technical assets which are either accessed by out-of-scope unmanaged developer clients and/or are directly accessed by any kind of internet-located (non-VPN) component or are themselves directly located on the internet.
Rating: The risk rating depends on the confidentiality and integrity rating of the code being handled and deployed as well as the placement/calling of this technical asset on/from the internet.

Container Base Image Backdooring
container-baseimage-backdooring

STRIDE: Tampering
Description: When a technical asset is built using container technologies, Base Image Backdooring risks might arise where base images and other layers used contain vulnerable components or backdoors.
Detection: In-scope technical assets running as containers.
Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets.

Container Platform Escape
container-platform-escape

STRIDE: Elevation of Privilege
Description: Container platforms are especially interesting targets for attackers as they host big parts of a containerized runtime infrastructure. When not configured and operated with security best practices in mind, attackers might exploit a vulnerability inside an

container and escape towards the platform as highly privileged users. These scenarios might give attackers capabilities to attack every other container as owning the container platform (via container escape attacks) equals to owning every container.

Detection: In-scope container platforms.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Cross-Site Request Forgery (CSRF)

cross-site-request-forgery

STRIDE: Spoofing

Description: When a web application is accessed via web protocols Cross-Site Request Forgery (CSRF) risks might arise.

Detection: In-scope web applications accessed via typical web access protocols.

Rating: The risk rating depends on the integrity rating of the data sent across the communication link.

Cross-Site Scripting (XSS)

cross-site-scripting

STRIDE: Tampering

Description: For each web application Cross-Site Scripting (XSS) risks might arise. In terms of the overall risk level take other applications running on the same domain into account as well.

Detection: In-scope web applications.

Rating: The risk rating depends on the sensitivity of the data processed or stored in the web application.

DoS-risky Access Across Trust-Boundary

dos-risky-access-across-trust-boundary

STRIDE: Denial of Service

Description: Assets accessed across trust boundaries with critical or mission-critical availability rating are more prone to Denial-of-Service (DoS) risks.

Detection: In-scope technical assets (excluding load-balancer) with availability rating of critical or higher which have incoming data-flows across a network trust-boundary (excluding devops usage).

Rating: Matching technical assets with availability rating of critical or higher are at low risk. When the availability rating is mission-critical and neither a VPN nor IP filter for the incoming data-flow nor redundancy for the asset is applied, the risk-rating is considered medium.

Incomplete Model

incomplete-model

STRIDE: Information Disclosure
Description: When the threat model contains unknown technologies or transfers data over unknown protocols, this is an indicator for an incomplete model.
Detection: All technical assets and communication links with technology type or protocol type specified as unknown.
Rating: low

LDAP-Injection
ldap-injection

STRIDE: Tampering
Description: When an LDAP server is accessed LDAP-Injection risks might arise. The risk rating depends on the sensitivity of the LDAP server itself and of the data assets processed or stored.
Detection: In-scope clients accessing LDAP servers via typical LDAP access protocols.
Rating: The risk rating depends on the sensitivity of the LDAP server itself and of the data assets processed or stored.

Missing Authentication
missing-authentication

STRIDE: Elevation of Privilege
Description: Technical assets (especially multi-tenant systems) should authenticate incoming requests when the asset processes or stores sensitive data.
Detection: In-scope technical assets (except load-balancer, reverse-proxy, service-registry, waf, ids, and ips and in-process calls) should authenticate incoming requests when the asset processes or stores sensitive data. This is especially the case for all multi-tenant assets (there even non-sensitive ones).
Rating: The risk rating (medium or high) depends on the sensitivity of the data sent across the communication link. Monitoring callers are exempted from this risk.

Missing Two-Factor Authentication (2FA)
missing-authentication-second-factor

STRIDE: Elevation of Privilege
Description: Technical assets (especially multi-tenant systems) should authenticate incoming requests with two-factor (2FA) authentication when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by humans.
Detection: In-scope technical assets (except load-balancer, reverse-proxy, waf, ids, and ips) should authenticate incoming requests via two-factor authentication (2FA) when the asset processes or stores highly sensitive data (in terms of confidentiality, integrity, and availability) and is accessed by a client used by a human user.
Rating: medium

Missing Build Infrastructure
missing-build-infrastructure

STRIDE: Tampering

Description: The modeled architecture does not contain a build infrastructure (devops-client, sourcecode-repo, build-pipeline, etc.), which might be the risk of a model missing critical assets (and thus not seeing their risks). If the architecture contains custom-developed parts, the pipeline where code gets developed and built needs to be part of the model.

Detection: Models with in-scope custom-developed parts missing in-scope development (code creation) and build infrastructure components (devops-client, sourcecode-repo, build-pipeline, etc.).

Rating: The risk rating depends on the highest sensitivity of the in-scope assets running custom-developed parts.

Missing Cloud Hardening
missing-cloud-hardening

STRIDE: Tampering

Description: Cloud components should be hardened according to the cloud vendor best practices. This affects their configuration, auditing, and further areas.

Detection: In-scope cloud components (either residing in cloud trust boundaries or more specifically tagged with cloud provider types).

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Missing File Validation
missing-file-validation

STRIDE: Spoofing

Description: When a technical asset accepts files, these input files should be strictly validated about filename and type.

Detection: In-scope technical assets with custom-developed code accepting file data formats.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Missing Hardening
missing-hardening

STRIDE: Tampering

Description: Technical assets with a Relative Attacker Attractiveness (RAA) value of 55 % or higher should be explicitly hardened taking best practices and vendor hardening guides into account.

Detection: In-scope technical assets with RAA values of 55 % or higher. Generally for high-value targets like datastores, application servers, identity providers and ERP systems this limit is reduced to 40 %

Rating: The risk rating depends on the sensitivity of the data processed or stored in the technical asset.

Missing Identity Propagation
missing-identity-propagation

STRIDE: Elevation of Privilege

Description: Technical assets (especially multi-tenant systems), which usually process data for endusers should authorize every request based on the identity of the enduser when the data flow is authenticated (i.e. non-public). For DevOps usages at least a technical-user authorization is required.

Detection: In-scope service-like technical assets which usually process data based on enduser requests, if authenticated (i.e. non-public), should authorize incoming requests based on the propagated enduser identity when their rating is sensitive. This is especially the case for all multi-tenant assets (there even less-sensitive rated ones). DevOps usages are exempted from this risk.

Rating: The risk rating (medium or high) depends on the confidentiality, integrity, and availability rating of the technical asset.

Missing Identity Provider Isolation
missing-identity-provider-isolation

STRIDE: Elevation of Privilege

Description: Highly sensitive identity provider assets and their identity datastores should be isolated from other assets by their own network segmentation trust-boundary (execution-environment boundaries do not count as network isolation).

Detection: In-scope identity provider assets and their identity datastores when surrounded by other (not identity-related) assets (without a network trust-boundary in-between). This risk is especially prevalent when other non-identity related assets are within the same execution environment (i.e. same database or same application server).

Rating: Default is high impact. The impact is increased to very-high when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

Missing Identity Store
missing-identity-store

STRIDE: Spoofing

Description: The modeled architecture does not contain an identity store, which might be the risk of a model missing critical assets (and thus not seeing their risks).

Detection: Models with authenticated data-flows authorized via enduser-identity missing an in-scope identity store.

Rating: The risk rating depends on the sensitivity of the enduser-identity authorized technical assets and their data assets processed and stored.

Missing Network Segmentation

missing-network-segmentation

STRIDE: Elevation of Privilege

Description: Highly sensitive assets and/or datastores residing in the same network segment than other lower sensitive assets (like webservers or content management systems etc.) should be better protected by a network segmentation trust-boundary.

Detection: In-scope technical assets with high sensitivity and RAA values as well as datastores when surrounded by assets (without a network trust-boundary in-between) which are of type client-system, web-server, web-application, cms, web-service-rest, web-service-soap, build-pipeline, sourcecode-repository, monitoring, or similar and there is no direct connection between these (hence no requirement to be so close to each other).

Rating: Default is low risk. The risk is increased to medium when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

Missing Vault (Secret Storage)

missing-vault

STRIDE: Information Disclosure

Description: In order to avoid the risk of secret leakage via config files (when attacked through vulnerabilities being able to read files like Path-Traversal and others), it is best practice to use a separate hardened process with proper authentication, authorization, and audit logging to access config secrets (like credentials, private keys, client certificates, etc.). This component is usually some kind of Vault.

Detection: Models without a Vault (Secret Storage).

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Missing Vault Isolation

missing-vault-isolation

STRIDE: Elevation of Privilege

Description: Highly sensitive vault assets and their datastores should be isolated from other assets by their own network segmentation trust-boundary (execution-environment boundaries do not count as network isolation).

Detection: In-scope vault assets when surrounded by other (not vault-related) assets (without a network trust-boundary in-between). This risk is especially prevalent when other non-vault related assets are within the same execution environment (i.e. same database or same application server).

Rating: Default is medium impact. The impact is increased to high when the asset missing the trust-boundary protection is rated as strictly-confidential or mission-critical.

Missing Web Application Firewall (WAF)

missing-waf

STRIDE: Tampering
Description: To have a first line of filtering defense, security architectures with web-services or web-applications should include a WAF in front of them. Even though a WAF is not a replacement for security (all components must be secure even without a WAF) it adds another layer of defense to the overall system by delaying some attacks and having easier attack alerting through it.
Detection: In-scope web-services and/or web-applications accessed across a network trust boundary not having a Web Application Firewall (WAF) in front of them.
Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Mixed Targets on Shared Runtime
mixed-targets-on-shared-runtime

STRIDE: Elevation of Privilege
Description: Different attacker targets (like frontend and backend/datastore components) should not be running on the same shared (underlying) runtime.
Detection: Shared runtime running technical assets of different trust-boundaries is at risk. Also mixing backend/datastore with frontend components on the same shared runtime is considered a risk.
Rating: The risk rating (low or medium) depends on the confidentiality, integrity, and availability rating of the technical asset running on the shared runtime.

Path-Traversal
path-traversal

STRIDE: Information Disclosure
Description: When a filesystem is accessed Path-Traversal or Local-File-Inclusion (LFI) risks might arise. The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed or stored.
Detection: Filesystems accessed by in-scope callers.
Rating: The risk rating depends on the sensitivity of the data stored inside the technical asset.

Push instead of Pull Deployment
push-instead-of-pull-deployment

STRIDE: Tampering
Description: When comparing push-based vs. pull-based deployments from a security perspective, pull-based deployments improve the overall security of the deployment targets. Every exposed interface of a production system to accept a deployment increases the attack surface of the production system, thus a pull-based approach exposes less attack surface relevant interfaces.
Detection: Models with build pipeline components accessing in-scope targets of deployment (in

a non-readonly way) which are not build-related components themselves.

Rating: The risk rating depends on the highest sensitivity of the deployment targets running custom-developed parts.

Search-Query Injection
search-query-injection

STRIDE: Tampering

Description: When a search engine server is accessed Search-Query Injection risks might arise.

Detection: In-scope clients accessing search engine servers via typical search access protocols.

Rating: The risk rating depends on the sensitivity of the search engine server itself and of the data assets processed or stored.

Server-Side Request Forgery (SSRF)
server-side-request-forgery

STRIDE: Information Disclosure

Description: When a server system (i.e. not a client) is accessing other server systems via typical web protocols Server-Side Request Forgery (SSRF) or Local-File-Inclusion (LFI) or Remote-File-Inclusion (RFI) risks might arise.

Detection: In-scope non-client systems accessing (using outgoing communication links) targets with either HTTP or HTTPS protocol.

Rating: The risk rating (low or medium) depends on the sensitivity of the data assets receivable via web protocols from targets within the same network trust-boundary as well on the sensitivity of the data assets receivable via web protocols from the target asset itself. Also for cloud-based environments the exploitation impact is at least medium, as cloud backend services can be attacked via SSRF.

Service Registry Poisoning
service-registry-poisoning

STRIDE: Spoofing

Description: When a service registry used for discovery of trusted service endpoints Service Registry Poisoning risks might arise.

Detection: In-scope service registries.

Rating: The risk rating depends on the sensitivity of the technical assets accessing the service registry as well as the data assets processed or stored.

SQL/NoSQL-Injection
sql-nosql-injection

STRIDE: Tampering

Description: When a database is accessed via database access protocols SQL/NoSQL-Injection risks might arise. The risk rating depends on the sensitivity technical asset itself and of the data assets processed or stored.

Detection: Database accessed via typical database access protocols by in-scope clients.
Rating: The risk rating depends on the sensitivity of the data stored inside the database.

Unchecked Deployment
unchecked-deployment

STRIDE: Tampering
Description: For each build-pipeline component Unchecked Deployment risks might arise when the build-pipeline does not include established DevSecOps best-practices. DevSecOps best-practices scan as part of CI/CD pipelines for vulnerabilities in source- or byte-code, dependencies, container layers, and dynamically against running test systems. There are several open-source and commercial tools existing in the categories DAST, SAST, and IAST.
Detection: All development-relevant technical assets.
Rating: The risk rating depends on the highest rating of the technical assets and data assets processed by deployment-receiving targets.

Unencrypted Technical Assets
unencrypted-asset

STRIDE: Information Disclosure
Description: Due to the confidentiality rating of the technical asset itself and/or the processed data assets this technical asset must be encrypted. The risk rating depends on the sensitivity technical asset itself and of the data assets stored.
Detection: In-scope unencrypted technical assets (excluding reverse-proxy, load-balancer, waf, ids, ips and embedded components like library) storing data assets rated at least as confidential or critical. For technical assets storing data assets rated as strictly-confidential or mission-critical the encryption must be of type data-with-enduser-individual-key.
Rating: Depending on the confidentiality rating of the stored data-assets either medium or high risk.

Unencrypted Communication
unencrypted-communication

STRIDE: Information Disclosure
Description: Due to the confidentiality and/or integrity rating of the data assets transferred over the communication link this connection must be encrypted.
Detection: Unencrypted technical communication links of in-scope technical assets (excluding monitoring traffic as well as local-file-access and in-process-library-call) transferring sensitive data.
Rating: Depending on the confidentiality rating of the transferred data-assets either medium or high risk.

Unguarded Access From Internet

unguarded-access-from-internet

STRIDE: Elevation of Privilege

Description: Internet-exposed assets must be guarded by a protecting service, application, or reverse-proxy.

Detection: In-scope technical assets (excluding load-balancer) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) when accessed directly from the internet. All web-server, web-application, reverse-proxy, waf, and gateway assets are exempted from this risk when they do not consist of custom developed code and the data-flow only consists of HTTP or FTP protocols. Access from monitoring systems as well as VPN-protected connections are exempted.

Rating: The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

Unguarded Direct Datastore Access

unguarded-direct-datastore-access

STRIDE: Elevation of Privilege

Description: Datastores accessed across trust boundaries must be guarded by some protecting service or application.

Detection: In-scope technical assets of type datastore (except identity-store-ldap when accessed from identity-provider and file-server when accessed via file transfer protocols) with confidentiality rating of confidential (or higher) or with integrity rating of critical (or higher) which have incoming data-flows from assets outside across a network trust-boundary. DevOps config and deployment access is excluded from this risk.

Rating: The matching technical assets are at low risk. When either the confidentiality rating is strictly-confidential or the integrity rating is mission-critical, the risk-rating is considered medium. For assets with RAA values higher than 40 % the risk-rating increases.

Unnecessary Communication Link

unnecessary-communication-link

STRIDE: Elevation of Privilege

Description: When a technical communication link does not send or receive any data assets, this is an indicator for an unnecessary communication link (or for an incomplete model).

Detection: In-scope technical assets' technical communication links not sending or receiving any data assets.

Rating: low

Unnecessary Data Asset

unnecessary-data-asset

STRIDE: Elevation of Privilege

Description: When a data asset is not processed or stored by any data assets and also not transferred by any communication links, this is an indicator for an unnecessary data asset (or for an incomplete model).

Detection: Modelled data assets not processed or stored by any data assets and also not transferred by any communication links.

Rating: low

Unnecessary Data Transfer

unnecessary-data-transfer

STRIDE: Elevation of Privilege

Description: When a technical asset sends or receives data assets, which it neither processes or stores this is an indicator for unnecessarily transferred data (or for an incomplete model). When the unnecessarily transferred data assets are sensitive, this poses an unnecessary risk of an increased attack surface.

Detection: In-scope technical assets sending or receiving sensitive data assets which are neither processed nor stored by the technical asset are flagged with this risk. The risk rating (low or medium) depends on the confidentiality, integrity, and availability rating of the technical asset. Monitoring data is exempted from this risk.

Rating: The risk assessment is depending on the confidentiality and integrity rating of the transferred data asset either low or medium.

Unnecessary Technical Asset

unnecessary-technical-asset

STRIDE: Elevation of Privilege

Description: When a technical asset does not process or store any data assets, this is an indicator for an unnecessary technical asset (or for an incomplete model). This is also the case if the asset has no communication links (either outgoing or incoming).

Detection: Technical assets not processing or storing any data assets.

Rating: low

Untrusted Deserialization

untrusted-deserialization

STRIDE: Tampering

Description: When a technical asset accepts data in a specific serialized form (like Java or .NET serialization), Untrusted Deserialization risks might arise.

Detection: In-scope technical assets accepting serialization data formats (including EJB and RMI protocols).

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored.

Wrong Communication Link Content
wrong-communication-link-content

STRIDE: Information Disclosure

Description: When a communication link is defined as readonly, but does not receive any data asset, or when it is defined as not readonly, but does not send any data asset, it is likely to be a model failure.

Detection: Communication links with inconsistent data assets being sent/received not matching their readonly flag or otherwise inconsistent protocols not matching the target technology type.

Rating: low

Wrong Trust Boundary Content
wrong-trust-boundary-content

STRIDE: Elevation of Privilege

Description: When a trust boundary of type network-policy-namespace-isolation contains non-container assets it is likely to be a model failure.

Detection: Trust boundaries which should only contain containers, but have different assets inside.

Rating: low

XML External Entity (XXE)
xml-external-entity

STRIDE: Information Disclosure

Description: When a technical asset accepts data in XML format, XML External Entity (XXE) risks might arise.

Detection: In-scope technical assets accepting XML data formats.

Rating: The risk rating depends on the sensitivity of the technical asset itself and of the data assets processed and stored. Also for cloud-based environments the exploitation impact is at least medium, as cloud backend services can be attacked via SSRF (and XXE vulnerabilities are often also SSRF vulnerabilities).

Disclaimer

vonst conducted this threat analysis using the open-source Threagile toolkit on the applications and systems that were modeled as of this report's date. Information security threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much threat modeling is conducted. It is recommended to execute threat modeling and also penetration testing on a regular basis (for example yearly) to ensure a high ongoing level of security and constantly check for new attack vectors.

This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. vonst and the Threagile toolkit offers no warranties, representations or legal certifications concerning the applications or systems it tests. All software includes defects: nothing in this document is intended to represent or warrant that threat modeling was complete and without error, nor does this document represent or warrant that the architecture analyzed is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. Threat modeling tries to analyze the modeled architecture without having access to a real working system and thus cannot and does not test the implementation for defects and vulnerabilities. These kinds of checks would only be possible with a separate code review and penetration test against a working system and not via a threat model.

By using the resulting information you agree that vonst and the Threagile toolkit shall be held harmless in any event.

This report is confidential and intended for internal, confidential use by the client. The recipient is obligated to ensure the highly confidential contents are kept secret. The recipient assumes responsibility for further distribution of this document.

In this particular project, a timebox approach was used to define the analysis effort. This means that the author allotted a prearranged amount of time to identify and document threats. Because of this, there is no guarantee that all possible threats and risks are discovered. Furthermore, the analysis applies to a snapshot of the current state of the modeled architecture (based on the architecture information provided by the customer) at the examination time.

Report Distribution

Distribution of this report (in full or in part like diagrams or risk findings) requires that this disclaimer as well as the chapter about the Threagile toolkit and method used is kept intact as part of the distributed report or referenced from the distributed parts.